

Atividade Objetiva 2

- Entrega Sem prazo
- Pontos 20
- Perguntas 5
- Limite de tempo Nenhum
- Tentativas permitidas Sem limite

Instruções

O objetivo desta atividade é proporcionar uma melhor fixação quanto ao conteúdo da unidade 2. Com isso você será capaz de ter um entendimento das abordagens apresentadas na unidade.

Para iniciar o questionário:

- Clique em "**Fazer o teste**";
- Responda todas as questões e depois clique no botão "**Enviar teste**" para finalizar a atividade.

Depois de enviar seu questionário, clique no botão "**Próximo**" logo abaixo para continuar. ↓

Fazer o teste novamente

Histórico de tentativas

	Tentativa	Tempo	Pontuação
MANTIDO	Tentativa 2	2 minutos	20 de 20
MAIS RECENTE	Tentativa 2	2 minutos	20 de 20
	Tentativa 1	7 minutos	12 de 20

❗ As respostas corretas estão ocultas.

Pontuação desta tentativa: 20 de 20

Enviado 6 abr em 12:05

Esta tentativa levou 2 minutos.



Pergunta 1

4 / 4 pts

Uma empresa, como parte da sua Cultura DevSecOps, adotou como prática do processo a Modelagem de Ameaças. A adoção da Modelagem de Ameaças é amplamente recomendada como prática do processo de desenvolvimento seguro. Neste sentido, a empresa resolveu adotar para a classificação de ameaças a metodologia STRIDE.

Qual é o conceito de impedir que um sujeito (entidade que representa um usuário no sistema) negue uma ação anterior sobre um objeto em um sistema?

- ☐ Auditoria
- ☐ Autorização
- ☒ Não Repúdio

Correto. Não repúdio (ou Irretratabilidade) suporta o requisito de garantir que um sujeito não negue uma ação realizada por meio da autenticidade e controles como chave privada, secrets, entre outros.

- ☐ Controle de Acesso



Pergunta 2

4 / 4 pts

Uma empresa possui uma estrutura organizacional segmentada em Squads. Há aproximadamente 20 (vinte) Squads que atuam com o desenvolvimento de software. Há ainda uma área de Operação com uma proporção quantitativa de 1/3 do número de desenvolvedores e uma área de Segurança da informação com uma proporção quantitativa de 1/5 do número de desenvolvedores. A empresa deseja, como parte da sua cultura DevSecOps que a segurança da informação seja patente nas Squads.

Considerando a estratégia requerida da Organização, para atingir este objetivo, a **MELHOR** proposta seria:

- ☐ Investir em Headcount na área de Segurança da Informação em proporção quantitativa, no mínimo, em paridade à área de Operação.
- ☐ Investir na formação de um programa de Security Champion de um profissional da área Segurança da Informação, proporcionando treinamentos adequados de desenvolvimento de software, e inseri-lo na área de Desenvolvimento.
- ☐ Investir em Headcount na área de Segurança da Informação em proporção quantitativa, no mínimo, em paridade à área de Desenvolvimento.

☒ Investir na formação de um programa de Security Champion de um profissional da área Desenvolvimento, proporcionando treinamentos adequados em desenvolvimento seguro de software.
Correto. Security Champion é uma prática amplamente recomendada e deve ser considerado o treinamento de desenvolvedores em práticas de segurança no desenvolvimento seguro de software.



Pergunta 3

4 / 4 pts

Uma empresa adotou um sistema de monitoramento de um produto de software da Web lançado no mercado para ser utilizado por milhares de usuários. A adoção do monitoramento foi enfatizada uma vez que no processo de desenvolvimento de software uma das preocupações era que devido à complexidade da aplicação Web, comportamentos anômalos e não controlados ocorressem, culminando, inclusive, em falhas de segurança. A empresa considerou, como uma estratégia para minimizar este problema, adotar os controles proativos da OWASP.

Dos controles proativos da OWASP, qual foi adotado para o cenário em questão:

☒ Tratamento de Erros e Exceções.

Correto. O Tratamento de Erros e Exceções ajudam a controlar o fluxo do software, inclusive, antecipando o comportamento em circunstâncias adversas que podem provocar falhas de segurança, também.

☐ Implementação de Logs e Monitoramento de Segurança.

☐ Codificação e Sanitização/Escape dos Dados.

☐ Validação de Todas as Entradas.



Pergunta 4

4 / 4 pts

A adoção da Modelagem de Ameaças é amplamente recomendada como prática do processo de desenvolvimento seguro. Uma empresa está aplicando esta abordagem para um sistema da Web que possui três camadas: Frontend, Backend e Persistência (sistemas de banco de dados).

Durante a classificação das ameaças, por meio da metodologia STRIDE, considerou-se que a camada de Persistência possui menor grau no limite de confiança e maior grau na superfície de ataque, e neste sentido, as respectivas ameaças capitais foram estabelecidas nesta premissa. Tal consideração, a partir de uma análise do fator de exposição ao risco, pode ser considerada:



Coerente. A camada de Persistência, devido a um fator de exposição superior às outras camadas, possui ainda maior grau da superfície de ataque e menor grau de limite de confiança.



Coerente. A camada de Persistência, devido a um fator de exposição superior às outras camadas, possui ainda maior grau de superfície de ataque e menor grau de limite de confiança.



Incoerente. A camada de Persistência, devido a um fator de exposição inferior às outras camadas, possui ainda maior grau da superfície de ataque e menor grau de limite de confiança.



Incoerente. A camada de Persistência, devido a um fator de exposição inferior às outras camadas, possui ainda menor grau de superfície de ataque e maior grau no limite de confiança.

Correto. A camada de persistência possui fator de exposição inferior, menor grau da superfície de ataque e maior grau do limite de confiança.



Pergunta 5

4 / 4 pts

Uma empresa, como parte da sua Cultura DevSecOps, adotou como prática do processo a Modelagem de Ameaças. A adoção da Modelagem de Ameaças é amplamente recomendada como prática do processo de desenvolvimento seguro. Neste sentido, a empresa resolveu adotar para a classificação de ameaças a metodologia STRIDE.

Durante a análise de um diagrama de fluxo de dados de uma função crítica da aplicação Web, observou-se que em dado perfilamento que estava sendo considerado, houve uma preocupação de que um agente da ameaça realizasse ações sobre objetos (partes da aplicação manipuláveis pelo

usuário) e, portanto, acessar informações não vinculativas ao seu nível de acesso. É correto afirmar que esta empresa ao adotar a metodologia STRIDE, considerou o seguinte:

- ☐ Adulteração (Tampering), portanto, Integridade.
- ☒ Elevação de Privilégio (Elevation of Privilege), portanto, Autorização.

Correto. No contexto de perfilamento e acesso a objetos do sistema, trata-se do controle de acesso, portanto, Autorização.

- ☐ Spoofing, portanto, Autenticação.
- ☐ Vazamento de Informação (Information Disclosure), portanto, Confidencialidade.

Pontuação do teste: 20 de 20